Cloud Security Risks and Mitigation Strategies for E-Commerce Platforms

Balint Eliza-Iuliana and Bodnar Florina-Alina

Department of Computer Science, UAIC IASI: elizabalint2002@gmail.com, bodnarflorina55@gmail.com

October 2025

Abstract

This paper examines the most important security issues to e-commerce systems migrating into cloud providers. Utilizing a Systematic Literature Review (SLR), the study creates the basis of risks-centered on misconfigurations, IAM vulnerabilities, and the complexity of the Shared Responsibility Model (SRM). To overcome these weaknesses, the paper outlines a multi-layered protection plan, including data encryption, structural separation, and strict governance. The effectiveness of such controls in practice are confirmed by the analysis of the Capital One Data Breach that revealed the example of how violation of the Principle of Least Privilege contributes to failures in the system. It concludes on the point that ensuring cloud-hosted e-commerce is an ongoing task that organizations should consider deploying sound technical protection and consider security a primary business activity to be resilient and keep customers trusting them.

1 Introduction

This document addresses the critical need for customer data security in today's e-commerce ecosystem. E-commerce, which has been evolving over the last couple of decades, is no longer confined to mere buying and selling of goods over the Internet, but also a number of companies have introduced software, systems, and infrastructure as their deliverables under e-commerce: SaaS, PaaS, IaaS. [10]

Cloud computing is one of the major strategies that will provide elasticity, scalability, and cost efficiency in the widespread adoption of e-commerce. [10] E-commerce integrated with cloud computing works on a Pay-Per-Use-On-Demand mode for easy access and sharing of IT resources over the internet. This transition demands rigorous protective measures to safeguard customer data. [6]

E-commerce websites retain hundreds of thousands of records of personally identifiable information and financial data. [9] The protection of this information is not only a compliance requirement but also a means to maintain consumer confidence and ensure business survivability. Data and computer security has a direct impact on e-commerce cloud performance. E-commerce security is considered a multidiscipline area of study, relating to both network security and commercial security topics. [5] Any website offering online payment options-such as net banking, credit cards, debit cards, or PayPal-is at greater risk. Privacy

has become a significant concern for consumers due to increasing cases of identity theft. [10]

This analysis is defined within the scope of addressing two core questions:

1. What are the main cloud security risks for online retailers?
2. What countermeasures effectively reduce these determined threats?

2 Methodology

A Systematic Literature Review (SLR) is the main method used in this study. This approach is known for its structured way of combining and pulling together a vast amount of information from a variety of reliable academic and professional sources, which has helped in establishing solid cloud security knowledge specific to e-commerce.

The SLR process involved the following key steps:

- **Sources determination:** We paid extra attention to incorporate findings and data from top academic journals, peer-reviewed conference proceedings, or even technical reports from worldwide standardization organizations or reputable security vendors.
- **Selection criteria documentary and thematic:** The selection process of literature is based on strict documentary and thematic criteria focusing primarily on studies published over the past decade. This restriction guarantees the temporal relevance of the information given the perpetually evolving nature of the cloud computing technological and threat landscape.
- **Research content:** The review deliberately focused on literature existing at the convergence of the following three themes:
  - Threats specific to the cloud environment.
  - Common vulnerabilities in cloud-based e-commerce architectures.
  - Countermeasures effectiveness and proposed security measures.

This ensures that all derived conclusions, and the subsequent set of best practices suggested, are evidence-based, resulting from a critical analysis of recognized digital libraries and databases. The final goal is to answer correctly and comprehensively the proposed research questions, with a view to offering an informed and practical standpoint for enhancing the resilience of e-commerce platforms in the cloud environment.

3 Theoretical Foundations

Security considerations for Cloud Security are based on the universally-accepted Confidentiality, Integrity, and Availability (CIA) triad model. The three-letter

acronym represents the most fundamental security needs of all systems, including cloud-based infrastructure, data, and applications. [3]

The CIA triad defines three main objectives of security:

1. **Confidentiality (C):** Confidentiality is making sure information is not disclosed to unauthorized persons. Confidentiality is all about protecting sensitive data from unauthorized disclosure or access. Data breaches represent a direct compromise of confidentiality. [6]

2. **Integrity (I):** Integrity is protection against unauthorized modification. [10] The integrity principle ensures that data is trustworthy and free from tampering or modification (intentional or unintentional) by unauthorized users. [6]

3. **Availability (A):** Availability means ensuring that information and critical services are available anywhere and at any time, and without time limit. [10] Problems like Distributed Denial of Service (DDoS) attacks threaten availability; network security is essential for assuring information availability. [3] Reliability also means being able to repair and recover a system quickly and efficiently after an interruption. [4]

The Critical Shared Responsibility Model (SRM)

The CIA triad describes *what* must be protected, the **Shared Responsibility Model (SRM)** describes *who* must protect it in a cloud environment. [1] The model is essential to achieving proper security governance.

The SRM states that security is a shared responsibility between the Cloud Service Provider (CSP) and the customer. [1] Uncertainty about these responsibilities can lead to gaps in implementation and therefore to security gaps. [3]

Cloud Provider Responsibility (Security *of* the Cloud): The cloud provider (e.g. AWS, Google, or Microsoft) is responsible for securing the underlying infrastructure. [4] This means controlling, operating, and managing components from the host OS and virtualization layer down to the physical security of the facilities that host the services. The SRM helps to shift the operational burden from the customer in these areas. [1]

Customer Role (Cloud Security Areas): The customer (the corporation using cloud infrastructure, an e-commerce platform) is accountable for and manages the security in the cloud. This includes protecting the following areas the customer can impact:

- **Data:** The customer is responsible for security of the data they put on the cloud. [9] This requires security solutions in addition to those deployed by the CSP, such as encryption of data both at rest and in transit [2] and proper key management. [4]

- **Applications/software:** The customer is responsible for managing the guest operating system (including updates and security patches) and other associated application software. [1] Application security flaws, like those identified by OWASP, are the customer's responsibility. [8]

- **Configurations and Access Control:** The customer must implement secure configuration and access controls. [9] These controls include permissions and policies for **Identity and Access Management (IAM)**. [4] Most importantly, it is the customer who is responsible for managing the configuration of the cloud provider's security group firewall. Misconfiguration (ie. a WAF, as in the Capital One Breach) is a failure of the customer's responsibility under the SRM. [1]

- **Maintaining Rules:** For all Identity and Access Management (IAM) policies and roles, customers need to support and improve mature security practices such as least privilege. [4] And they must maintain a **"trust but verify"** security practice because a common flaw is the blind reliance on the CSP's security model. [1]

If these roles are not clearly defined and managed, it can lead to the loss of sensitive information. [1] As a result, clear Service Level Agreements (SLAs) are important contractual protections for assigning clear roles and expectations between the customer and the CSP related to security and data protection. [4]

4 Main Cloud Security Risks for Online Stores

Hackers can use weaknesses in cloud models to steal information. Online stores are often affected by data breaches and data leakage. This is a big problem because these stores handle and keep a lot of private information, such as payments, personal details, and past purchases. Data breaches are characterized by unauthorized access to sensitive data and, if successful, can lead to severe consequences, such as substantial financial loss, unauthorized transactions, and serious reputational damage for the company involved. [11]

Many security incidents are caused by basic issues in the way cloud security is set up. Attackers look for these problems. Misconfigured cloud settings are a leading cause of cloud security breaches. [2] The well-publicized Capital One breach of over 100 million records was traced back to a misconfigured WAF. [1] Also, with multi-tenancy, which is common in a cloud environment since there is the chance of having different customers on the same physical hardware, there is a risk of data co-residency and potential data exposure or leakage between tenants. Not using proper encryption practices makes the data easily accessible or stolen. [2]

Distributed Denial-of-Service (DDoS) attacks are another major threat. This attacks target availability by attempting to interrupt the normal functioning of

an e-commerce system through intentionally overloading the target with too much traffic or requests. [3] DDoS attacks work by attackers deploying software agents onto third party systems and triggering them to simultaneously send requests to the target. [10] Disruptions like these can impact the information and vital services available on the internet, endangering availability which is one of the three fundamental components of security.

Vulnerabilities associated with insecure Application Program Interfaces (APIs) present common attack paths for data compromise. APIs are an integral part of cloud services as they connect the different software elements. They serve as the main entry point for data sharing and application deployment. Insecure APIs is categorized as a High risk due to the potential data leaks, access, and DoS conditions that can result from exploitation of an API. [4] This risk is often compounded by weak authentication, insufficient authorization and the lack of data input validation. [8] Online payment websites are prone to such technical exploits.

4.1 Classification

The Importance of Risk Classification for Prioritization

Organizations can rank their defenses by making a proper risks classification based on the CIA triad, considering the likelihood and potential impact of each risk categories. These threats, which include technical and human-related risks, are essential for developing proper defensive strategies. [3]

Risk assessment models help define and prioritize security efforts:

- **Risk Assessment Models:** Risk analysis involves the systematic identification and assessment of hazards associated with cloud adoption and the development of appropriate mitigation strategies. [4] The computation of risk assessment results for information assets typically incorporates the values associated with the asset's confidentiality, integrity, and availability.

- **Quantitative Prioritization:** More advanced methodologies, such as Probabilistic Risk Assessment (PRA), are capable of quantifying both the likelihood and impact of specific security issues, allowing organizations to appropriately allocate resources (e.g., to secure APIs via enhanced authentication and monitoring if the risk of breach via insecure APIs is high). [3]

- **Systemic Analysis:** Other methodologies, such as the Cybersafety method, examine system conditions (hazards) that, if not controlled, violate fundamental security constraints. Hence, a constraint violation could be operating the system with overly broad access control (integrity/confidentiality constraint violations) or without protection against the delivery of exploits (availability constraint violation). [1]

When planning for security, it is not enough to know the threats. It is also important to know what security objective each of them violates. This allows

the organization to apply the correct mitigations, such as encryption (to protect confidentiality) and IAM policies (to protect integrity). [2]

When categorizing security risks, organizations classify threats based on which of fundamental objectives they violate. The shift toward cloud operations has highlighted that threats affecting data availability, integrity, and confidentiality are key challenges that must be overcome. [10]

1. **Threats to Confidentiality (Data Leakage)**

   Making sure that information isn't accessible to unauthorized people is the goal of confidentiality. Whenever private data is made accessible or falls into the wrong hands, confidentiality has been compromised.

   - **Data breaches and leakage:** Data breaches, or unauthorized access to sensitive data, are the most commonly encountered challenge and threaten confidentiality. Data leakage can occur when data goes into unauthorized systems during a transfer, audit, storage or processing. Data breaches are a serious concern in e-commerce environments where sensitive consumer data such as payment info, personal info or even specific purchasing histories may be stored. [11]
   - **Insecure APIs:** Insecure interfaces and APIs are among the most critical vulnerabilities, because flawed APIs (e.g., interfaces that use weak credentials or don't use authorization checks) can be used to gain direct access and lead to data breaches. [8]

2. **Threats to Integrity (Data Tampering)**

   Integrity threats mean someone changes, edits, or removes information without permission. This puts the information's accuracy and reliability at risk.

   - **Manipulation and tampering:** Threats like customer-data manipulation involve users exploiting web apps by modifying the data sent to the server (for example, through SQL injection or cross-site scripting). [8]
   - **Malicious Activity:** Integrity may also be threatened by a malware attack. Also, threats from malicious insiders may involve sabotage or data manipulation. [4]
   - **Risk Management Focus:** Security practices, security protocols, security architecture, and security technology are designed to ensure the integrity of e-commerce business processes. Often, the development of security policies is focused on the integrity of data as much as on confidentiality and availability. [6]

3. **Threats to Availability (DDoS)**

   Attacks that are focused on availability aim to disrupt normal business operations.

- **Denial of Service (DoS) Attacks:** A Denial of Service (DoS) attack occurs when a malicious user consumes system resources, making them unavailable for legitimate users. [8]
- **DDoS Attack (Distributed Denial-of-Service):** DDoS attacks are a particular form of attack aimed at disrupting a company system's availability by overpowering it with excessive traffic. DDoS requires sophisticated network security capabilities to maintain continuous availability. [3]
- **Data Loss:** Data loss, either due to hardware failure, accidental deletion, or malicious deletion, causes disruption of operations and is considered a violation of the availability principle. [2]

Here is a detailed classification of cloud security risks:

I. Operational and Managerial Security Threats

These threats are often rooted in flawed policies, configuration errors, or malicious/negligent human behavior, and frequently carry a **Medium to High** risk level.

Risk Category	**Description of Threat**	**Affected Layer(s) & Risk Level**
Lack of Customer Background Checks	Most cloud providers do not check their customer's background; almost anyone can open an account, which allows attackers to perform malicious activity without being identified. [10]	Systemic

II. Technical and Infrastructure Vulnerabilities

These risks target the technical components of the cloud delivery model (IaaS, PaaS, SaaS) and often leverage flaws in design or configuration.

Risk Category	**Description of Threat/Vulnerability**	**Affected Layer(s) & Risk Level**
Virtualization Vulnerabilities	Risks associated with the virtualization layer (hypervisor, VMs). These are flaws that allow an attacker to compromise the virtualization infrastructure or obtain **unauthorized access to VMs**. [10]	IaaS; **High Risk**
VM Escape/Hopping	Attack designed to exploit the hypervisor to take control of the underlying infrastructure (VM escape). VM hopping occurs when one VM gains access to another by exploiting hypervisor vulnerabilities. [10]	IaaS
Insecure VM Migration	Live migration of VMs exposes the VM state files to the network, allowing an attacker to access data during migration or transfer a VM to an untrusted host. [8]	IaaS
Malicious VM Creation	An attacker creates a VM image containing malicious code (e.g., a Trojan horse) and stores it in the provider repository, compromising other users who use that image. [8]	IaaS
Shared Resource Vulnerabilities	In multi-tenancy models, VMs on the same server share resources (CPU, memory, I/O). A malicious VM can infer information about other VMs through shared memory or covert channels, bypassing VMM security. [10]	IaaS
Sniffing/Spoofing Virtual Networks	A malicious VM can listen to the virtual network or use ARP spoofing to redirect packets from/to other VMs. Virtual bridges shared by many VMs are vulnerable. [10]	IaaS

III. Data and Regulatory Risks

These risks involve the handling and legal compliance surrounding sensitive data, which are especially critical for e-commerce.

Risk Category	**Description of Threat/Vulnerability**	**Affected Layer(s) & Risk Level**
Uncontrolled Snapshots/Rollback	Virtual machines can be copied (snapshots) to provide flexibility, which may lead to data leakage if the image is not "cleaned" of confidential information such as passwords or cryptographic keys. [8]	IaaS
Data Location and Jurisdiction	Uncertainty about the physical location of data can cause conflicts with data protection regulations and legal jurisdictions. Data located in different jurisdictions may be subject to different laws. Compliance with regulations like GDPR and HIPAA adds complexity. [10]	Systemic/ Regulatory
Third-Party Risk	The use of third-party cloud services can introduce vulnerabilities if those services lack stringent security measures. Data backup done by untrusted third-party providers is a specific vulnerability. [10]	Systemic
Service Continuity Risk	E-commerce firms are worried about whether appropriate measures are in place to ensure normal operation in the event of natural disasters or hardware failures. Downtime due to technical issues, maintenance, or cyberattacks severely disrupts platform operations. [10]	Operational/ Availability

4.2 Key Risk Presentation

This shift of e-commerce platforms to cloud environments presents a variety of critical risks that target data confidentiality and integrity. Such core risks, including misconfigurations, IAM failures, credential weaknesses, API vulnerabilities, and insider threats, reflect the operational and technical challenges in managing security within the Shared Responsibility Model.

1. **Operational Risks: Misconfiguration and IAM Failures**

   Most cloud security risks come through mistakes in configuration or failures in access management, which almost always lead to data exposure immediately.

   A. Cloud Resource Misconfigurations Leading to Data Exposure

   Cloud resource misconfigurations are a leading cause of frequent security incidents, which have greatly contributed to data breaches and the exposure of sensitive information. [2]

   - **Improper Configuration:** Common causes of data breaches are cloud settings that are wrongly configured. Misconfigurations bring in possible risks and gaps into the security posture. When an organization misses the phase of proper configuration and customization of security frameworks, they risk implementation gaps. [4]

   B. IAM Failures Because of Lack of Least Privilege

   Identity and Access Management systems are the key components that manage cloud resources as well as user identities. [6] Failures in IAM—in which users, processes, or roles are granted too many permissions—violate basic principles of security.

   - **The Principle of Least Privilege:** IAM solutions are necessary to manage user roles and permissions. According to the principle of least privilege, users should be given only those permissions which are necessary to perform their day-to-day activities. This makes the effective implementation of this principle minimize the possible risks. [4]

2. **Systemic Risks: Data Exfiltration and Credential Exploitation**

   It usually depends on the exploitation of authentication systems or credential weaknesses, which are the prime target for attackers seeking to gain unauthorized access to sensitive data. [2]

   A. Account Hijacking: It is considered one of the major security threats in cloud computing. Attackers often breach accounts using techniques such as credential stuffing or weak passwords. For example, a massive breach in

Dropbox in 2012 was because of compromised credentials of users from a third-party service. [2]

B. Consequences of Credential Exploitation: Once the attacker has successfully accessed the user credential, they perform malicious activities such as accessing sensitive data, tampering with data, and redirecting transactions. Successful hijacking may lead to data theft and cause severe financial loss. [4]

3. **Technical and Personnel Risks: APIs and Insider Threats**

   Attackers will take advantage of technical interfaces as well as human vulnerabilities to create persistence beyond basic configurations and credentials.

   A. API Vulnerabilities Used for Data Access

   Application Programming Interfaces (APIs) are what facilitate communications between the cloud services and applications. Given that cloud services use APIs for communication among the various parts that constitute software, this basically means that the security of the cloud depends on the security of these interfaces. [8]

   - **High Risk Exposure:** Insecure APIs are widely attacked and often lead to data leaks, unauthorized access, and Denial of Service attacks. [2]
   - **Vulnerability Vectors:** Poorly designed mechanisms, such as weak authentication mechanisms, weak authorization checks, and a lack of input-data validation, amplify API security risks. [8] Inadequate monitoring of API activities may result in delayed threat detection.

   B. Insider Threats from Privileged Personnel

   The risk from malicious insider threats originates from those who have authorized access to cloud resources. Insider threats have been classified as a Medium risk level. [4]

   - Insider threats can be defined as employees, contractors, or service providers with authorization who intentionally misuse their rights for malicious purposes. This may include data theft or leakage, unauthorized access, and even sabotage or data manipulation. [4]

4.3 Impact on Commercial Organizations

Security breaches are characterized by unauthorized access to sensitive data. If a data breach occurs, the repercussions are severe. These incidents ultimately translate into losses due to the violation of system safety and/or security constraints. [1]

1. **Substantial Financial and Legal Repercussions**

   Security breaches trigger significant financial and legal consequences, demanding massive resources for recovery, penalties, and compliance adjustments.

   - **Financial Loss:** Breaches directly cause financial loss for the company involved. If compromised data includes consumers' personal and financial information, the risk escalates, potentially leading to unauthorized transactions and severe financial losses. Data breaches expose an organization's private information, resulting in adverse financial outcomes. [3] Furthermore, data loss, which can occur due to malicious activity or human error, has consequences that include operational disruption and the loss of critical information.
   - **Legal Penalties and Compliance Issues:** Security incidents bring about legal consequences. Compliance with industry regulations and data protection laws is complex, and failing to meet requirements, such as those set by GDPR or HIPAA, can lead to severe legal consequences and heavy penalties. Non-compliance can also result in legal action. Additionally, establishing clear legal frameworks for accountability and culpability between customers and Cloud Service Providers (CSPs) remains an ongoing difficulty. Organizations often consult legal experts specializing in data protection laws to ensure compliance both domestically and internationally. [11]

2. **Devastating Reputational Damage and Loss of Trust**

   The long-term erosion of reputation and customer trust often poses the greatest threat to a company's market standing.

   - **Reputational Damage:** Data breaches lead to substantial reputational damage for the company involved. Data breaches expose an organization's private information, which results in adverse reputational outcomes. [3]
   - **Eroding Customer Trust:** Compromised accounts can harm the reputation and break customer trust for an organization. Privacy issues, such as the obscurity of algorithmic decision-making (the "black box" problem), can undermine trust, thereby impacting customer loyalty and engagement in the long term. Maintaining high security standards is necessary to keep gaining customer trust. [2]
   - **Market Standing and Business Continuity:** Service disruptions owing to technical issues or cyberattacks, especially DDoS attacks, seriously affect the e-commerce platform's operations. This operational failure contributes to the erosion of customer trust and satisfaction and causes great harm to the organization's brand and consumer confidence. The outcomes of a breach go beyond just the initial loss of

confidentiality but introduce negative impacts that force companies to take stringent security measures for data protection. [3]

5 Security Measures to Mitigate Cloud Risks

Having discussed the primary security threats of cloud environments of e-commerce platforms, it is necessary to concentrate on the means of mitigating these threats. A detailed risk reduction plan must integrate both technical and organizational measures and constant monitoring. The following measures represent best practices for reducing risks in cloud environments used by online stores.

5.1 Data Protection and Encryption

Protecting sensitive data is the key component of cloud security to e-commerce sites, which guarantees the data confidentiality and integrity directly, in case of unauthorized access to the physical infrastructure. All the customer and transactional information with this strategy is encrypted at rest (when stored) and in transit (when being passed over networks). [9]

In the data at rest, Symmetric encryption algorithms are generally deployed like the Advanced Encryption Standard (AES), as they are efficient in that the data cannot be understood in the event of any compromise that is caused in the storage layers. On the other hand, when it comes to data in transit, the protocols such as TLS/SSL (Transport Layer Security/Secure Socket Layer) which frequently are based on Asymmetric encryption (i. e. RSA) should be implemented on all communication to provide data transfers with safety and to limit the chances of interception during network transmission. In addition, the storage of user passwords will require the use of hashing algorithms, e.g. SHA-256, to make sure that the credentials are not stored in human-readable form. [8]

The whole usefulness of this encryption is based on the assumption of a very robust key management, in which keys must be operated by a hardened key-management service, which strictly separates keys and data it encrypts. Information The most important aspect of lifecycle hygiene is key rotation which is performed on a regular basis, good storage and implementation of fine-grained access of cryptographic material with clear procedures of key rotation and revocation. [9]

Organizations should use principles of Data Minimization and Tokenization to ensure that the sensitive surface area of data is further decreased. This is done by tokenization which is the process of substituting sensitive fields in applications and logs (such as payment card numbers) with non-sensitive equivalents (tokens) to greatly decrease the exposure risk linked to data exposure. [11] Lastly, content-aware Data Loss Prevention (DLP) systems need to be put into place to observe outbound channels and cloud sync paths and automatically prevent exfiltration of data based on data patterns that could suggest sensitive data. To use the state-

of-the-art, new techniques such as homomorphic encryption or format-preserving can be considered as well. [12]

This is a holistic approach required to sustain the confidentiality and integrity of consumer data, thus, safeguarding the reputation and compliance level of the e-commerce platform.

5.2 Identity and Access Management (IAM)

Unauthorized access remains one of the most common attack vectors in cloud environments. It is therefore important to have the strictest IAM controls in place to mitigate against the possibility of abusing of privileges, hacking of accounts and future data breaches. [10]

Secure access control is based on the principle of Least Privilege (PoLP). This principle states that the users, processes and applications must receive permission only to that which has been found absolutely necessary to carry out their daily tasks. By following PoLP, the risks linked to weakened credentials or mistakes are reduced to a minimum. Role-Based Access Control (RBAC) is the key mechanism that is employed to control user roles and permissions in order to grant granular control of resource access. In addition, permissions should be reviewed and updated on a regular basis to avoid privilege creep, in which users get access to things they do not need with time. [8]

Authentication should be strong to avoid the use of credential, which is one of the major targets of attackers. MFA should be implemented on all the administrative and customer-facing accounts. When used together with the passwords and possession factors (such as TOTP or FIDO), MFA makes identity verification much more robust. In the case of highly risky situations, adaptive authentication (or context-sensitive credentials) can be enforced, meaning that access permission is modified by risk indicators like location, device, or suspicious behavior. Finally, the organizations must keep in sync with Cloud Security Alliance IAM recommendations that emphasize on central directory, access credentials, and privileged session management to minimize more the chances of account hijacking. [9]

To be effective, security must be managed in such a way that it follows the credential lifecycle. The secrets (api keys, passwords) have to be changed regularly, and the duration of such tokens must be limited to diminish the timeframe of action in case of a stolen token. Privileged Access Governance and separation of duties should be provided, particularly access to critical infrastructure. Limiting access to production hosts directly and implementing workflows that are controlled to call break-glass operations limits the blast radius in case of credentials theft. [8]

Lastly, IAM systems must provide real-time user activity monitoring to identify anomalies to determine compromises or abuse of the system. This multi-layered, perimeter-to-core strategy substitutes the implicit trust with ongoing validation, which is to be expected by the principles of the Zero Trust Architecture, and needs to be implemented to maintain cloud resources and user identities in a secure condition. [9]

5.3 Secure Architecture and Isolation

Cloud platforms have to have a security-by-design attitude and consider the underlying infrastructure as a component of high risk and thus one that should be strongly isolated and continuously tested. Architectural security implies the principles to be implemented on all levels to restrict the blast radius of an intrusion and reduce the dangers of multi-tenant structures. [9]

The principle of Zero Trust Architecture (ZTA) is the main philosophy of secure cloud architecture that implements the principle of never-trust-always-verify. ZTA substitutes implicit trust by ongoing validation, which imposes the least-privilege access to micro-segmented services and by verifying the identity of the user and the health of their device at each request. This micro-segmentation entails that the network must be strictly divided, which includes de-escalation of operational tasks, ceding of direct access to production hosts and tiered administration to limit subsequent horizontal flow and constrain the blast radius in case of credentials compromise. [9]

Risks related to the virtualization layer (hypervisor and Virtual Machines, or VMs) are the key in cloud environments that use Infrastructure as a Service (IaaS). The way to respond to these risks is by Hypervisor Hardening in which the attack surface of the hypervisor needs to be reduced to the minimum, hardened, and completely patched. Control-flow integrity and memory lockdown (i.e. integrity protection) should be implemented to deter VM-escape and hypervisor attacks. Moreover, very strong segregation between virtual machines (VMs) should be implemented in order to avoid cross-tenant or "VM hopping" attacks. Organizations will need to use Resource Sharing Controls to suppress side channels and covert channels between co-located VMs by controlling shared physical infrastructure elements and either randomly or limiting co-residency of VM high-sensitivity workloads. [8]

Lastly, Virtual Network Security should be addressed by the use of defense-in-depth approach that prevents the packet sniffing, spoofing and lateral movement by unauthorized individuals in the environment. This is done by stringent Network Segmentation, implementation of stateful firewalls, secure routing modes, and virtual firewalls in order to restrict lateral movement within common environments. Policy Continuity is also necessary, where hypervisor-aware virtual network designs are necessary to ensure policy continuity when migrating VMs live, such that traffic guarantees that the workload moves. [8]

When such architectural controls are given priority, the e-commerce platforms will be able to set a strong security boundary that constrains the attack surface and offers higher control over security settings in a public cloud environment.

5.4 Application and API Security

The services and external integrations within e-commerce are supported by web applications and Application Programming Interfaces (APIs), which are used to

communicate between the services and external integrations. As a result, both they are common and dangerous targets to attackers, so protecting these interfaces is the priority to avoid data leakages and Denial of Service (DoS) situations.

Web Application Hardening is needed to safeguard the applications against frequent attacks which are mostly caused by lapses in secure coding. Applications These vulnerabilities can be mitigated by ensuring applications are resistant to common vulnerabilities, like injection attacks (i.e. SQL injection) and broken access control which are fundamental to the OWASP Top 10 list. This security is done by using secure coding practices, stringent input validation, and automated vulnerability scanning in the development pipeline (CI/CD) to minimize flaws prior to their release to production. Besides, a Web Application Firewall (WAF) should be implemented on the front of open ports to scan and deny any famous attack patterns, which offer a much-needed protection point against exploitation. [8]

Since APIs with insecure encryption, mostly because of a weak authentication or authorization, are some of the most urgent and significant vulnerabilities that result in direct access and data breach, Robust API Protection is obligatory. Every external and internal API needs to be handled through an API Gateway that serves as a focal point of authentication, authorization, fine-grained access control, versioning and threat protection. All API endpoints will have to be implemented with strict authentication (e.g. regular token-based authentication), stringent authorization procedures, and strict input-validation. Also, API monitoring and logging are necessary to identify suspicious behavior because other issues that are poorly monitored may result in a delay in threat detection. This multifaceted control approach can guarantee external integrations (including payments and logistics) will not create weak entry points or drift in the contract. [9]

E-commerce platforms can reduce the threat of technical exploits and the risk of data compromise significantly when the security measures are implemented early in the development process and the strong controls are enforced on the API gateway.

5.5 Monitoring, Auditing and Incident Response

Constant monitoring and the ability to respond quickly to any changing threat is critical in tracking and responding in real time. This role includes technical equipment and procedural guidelines that are needed to confirm the security controls are operable and business continuity in case of an emergency. [7]

The mean-time-to-detect (MTTD) and mean-time-to-respond (MTTR) should be reduced as soon as possible by continuous Monitoring and Threat Detection. Security Information and Event Management (SIEM) systems are mainly used to ensure proactive and centralized monitoring of the cloud environment, which compiles, analyzes as well as correlates logs of various sources (cloud services, applications, and endpoints) and provides an opportunity to detect threats in real-time and identify anomalies. With the additional functionality of AI/ML- Assisted

Detection and behavioral analytics, these functions are further augmented and contribute to detecting anomalies that suggest the possibility of an attack sooner than a conventional approach would. Moreover, the deployment of the Centralized Logging in the application, network, and virtualization drives is necessary to recreate the timelines of the post-incident forensics and trace infrastructure modifications. [12]

In addition to constant monitoring, the Auditing and Vulnerability Management also need periodic tests to ensure that security controls are operational, configurations are safe and regulatory measures are within the requirements. Companies need to perform periodic security and privacy testing, internal and third-party, to ensure the efficiency of encryption, access controls, and the compliance of the Service Level Agreement (SLAs). Such audits should also contain Compliance Checks with key industry regulations and requirements, including GDPR, PCI DSS, and ISO 27017 because failure to comply may result in a harsh legal penalty. Vulnerability Management involves periodic vulnerability scans and strict patch management in order to deal with any flaws effectively identified in the guest operating system and related application software. [7]

Last, but not least, the procedural protection against a security breach is a tested and clear Comprehensive Incident Response Plan. The Plan Development should provide the clear procedures of detecting, reporting and mitigating security breach including roles, communication procedures and recovery procedures. Automation and Playbooks are recommended to guarantee quick response, with automated alerts being linked to quick containment measures (e.g. token revocation, workload quarantine) to enable threats to be contained in minimal time before they become more severe. Testing and Review must be continuously revised and practiced in the plan, and all the staff members should know their roles, and the post-incident analysis must be performed to enhance resilience in the future. [9]

5.6 Backup and Disaster Recovery

One of the elements of risk management is data resilience, which guarantees the e-commerce site can withstand any data loss due to a cyber attack, human error, or system malfunction that would lead to business continuity and adhere to the principle of data availability of the CIA triad.

Strong and automated backup systems should be put in place in case of operational disruption and loss of vital information. This is by using automated and backup up of important customer and transactional information at secure and geographically dispersed sites to mitigate against localized disaster or failure in the region. [7] Backups should be versioned and immutable (can not be changed or deleted) so that they can be more resilient in case of an attack of ransomware or non-function of the infrastructure. Separate trust domains/regions should also be used to store them. In the case of Third-Party Risk Mitigation, although subcontracting is done in the process of backing up, even the back-ups must have

clear contractual agreements that stipulate tenant-conscious retention schedules as well as verifiable means of destruction to avert data leakage and scavenging. [9]

To reduce the severity of the damage and recovery goals, a formalized Disaster Recovery (DR) Plan is required and the recovery goals are to be achieved in case of an emergency. DR plans should consist of Tested Recovery Procedures and should be exercised on a regular basis to ensure continuity of a business. These tests are used to verify the achievement of recovery objectives with specific Recovery Point Objective (RPO) and Recovery Time Objective (RTO) target. To make the business continue, the plan ought to have multi-region replication and an established recovery process in order to restore and recover a system promptly and efficiently in case of an interruption. Moreover, an organization should practice role-specific runbooks (playbooks) and make sure that monitoring and logging are adequate to recreate post-incident forensic schedules. The automation of the recovery processes should also be periodically evaluated in order to determine their efficiency. [9]

Through an effective disaster-recovery plan and secure and redundant backups, e-commerce platforms can prevent the issue of data loss and downtime proactively, which causes an extremely negative impact on the operation of the platform and the loss of trust in its services.

5.7 Emerging Technologies and Advanced Models

In a bid to keep ahead of the ever-changing threat environment, organizations need to implement latest security models and technologies beyond the traditional perimeter protection. The new solutions play a pivotal role in improving resilience, effective defense, and integrity of data.

Zero Trust Architecture (ZTA) is a strategic security framework that fundamentally enhances the security of access control by altering the paradigm of security. As explained above, ZTA does not use implicit trust, but instead, it verifies the user, device, resource, posture, and so on with contextual policies, which is necessary to eliminate the lateral movement and threats inherent in multi-tenant clouds. [9]

In the same manner, the combination of Behavioral Analytics and Artificial Intelligence (AI) can be used to boost threat detection capability, as it offers predictive and anomaly-based protection mechanisms. The threat detection that is carried out by AI can provide the Proactive Defense by analyzing the patterns of user behavior and detecting anomalies that may signal the intent to attack. In particular, vulnerabilities can be predicted by using predictive analytics based on the Machine Learning (ML), allowing organizations to manage them before they are exploited. It leads to Enhanced Monitoring, in which anomaly detection with the help of AI/ML can identify suspicious activity (e.g. failed logins spurt, suspicious data transfers) and invoke playbooks to contain that activity, hence reducing mean-time-to-detect and mean-time-to-respond. [11]

Lastly, the Blockchain Technology, although commonly linked to the cryptocurrencies can also be used strategically towards the security. One can use it to guarantee Data Integrity and generate tamper-proof records of transactions, which increases resistance to unauthorized modification. [9]

With the combination of these sophisticated models, e-commerce firms can greatly boost their resilience to a level that they can predict and mitigate the threats that are not prevented by the conventional security measures.

5.8 Governance and Compliance

Effective regulatory frameworks and clear governance structures are the key to the safe functioning of the clouds. Governance stipulates the security policies and oversight mechanism, whereas compliance operates to implement the policies and the contractual requirements to reduce the significant legal and financial risks.

Roles should be well-defined and this is a critical aspect of cloud governance when using the Shared Responsibility Model (SRM). This involves the Explicit Definition of the shared responsibility model with Cloud Service Providers (CSPs) and third-party services and mapping the boundaries to the controls. Security and privacy should be negotiated as a contractual, rather than technical responsibility, which should be achieved by bargaining over Service-Level Agreements (SLAs) and data processing addenda that clearly outlines data protection, breach notification, uptime/availability and incident response responsibilities. It is best to avoid Gaps: it is important to clearly state what controls are the property of the provider (e.g. physical security) and what ones belong to the customer (e.g. application logic, access policies). The case of Capital One pointed out the way in which the SRM ambiguity can help to commit a significant breach. [10]

Given that e-commerce platforms deal with both personally identifiable information (PII) and financial data, there must be an element of Regulatory Adherence and Auditing. Legal and regulatory Compliance Verification with legal and regulatory frameworks, including the GDPR (General Data Protection Regulation) and PCI DSS (Payment Card Industry Data Security Standard) shall be checked by way of audits and documented procedures. Jurisdiction and Data Residency should also be considered as a design constraint. In order to ensure data residency controls, organizations need to categorize customer data based on sensitivity and map it to authorized storage/processing areas. It should have suitable safeguards where cross-border transfers are to be made. In addition, large reputable vendors, which provide information about their security control measures and their staff vetting procedures, and that can present known certifications (e.g. ISO/IEC 27001) should be preferred by organizations via Vendor Vetting. [10]

Organizations can securely implement and enforce security and privacy requirements in contracts and procurement checklists to confirm compliance before any workload becomes live to avoid legal liability and earn their customer trust.

5.9 Human Factor and Awareness

Human factor is still a major threat and area of weakness in cloud security. Social engineering or carelessness on the part of an insider can overcome even the most technologically sophisticated defenses. Thus, it is essential to develop a security-sensitive culture that would minimise the risk of insider attacks and unintentional violations.

This is achieved by means of Continuous Security Training. There should be regular and interactive training programs to sensitize employees and customers on how to identify and prevent security threats. Under Employee Education, continuous security training must comprise of phishing simulations and best-practice workshops, which would provide staff to be proactive in the reporting of suspicious events. In Customer Education, it is recommended to give clear instructions on how to evade unsafe usage of the shared or public computers when conducting sensitive operations and to promote usage of powerful, distinct credentials or passkeys. Social engineering, safe data handling practices, and phishing are very important issues that must be discussed in these Safe Practices training sessions. [10]

The larger objective is Fostering a Security-Conscious Culture in which security is integrated into organizational culture and business processes and is considered a central business operation, rather than a secondary one. The development of this culture helps to Reduce Insider Threat and accidental breaches by countering deliberate abuse or careless behavior of authorized staff members. Lastly, Accountability should be ensured through an environment where staff is encouraged to report any suspicions and other security principles are strictly followed. [10]

The human factor could be tackled by educational measures and cultural reinforcement, which means that e-commerce sites could reduce the chances of both unintentional information loss and intentional insider attacks to a significant degree.

The nine broad-based mitigation measures outlined in this paper provide a requisite defense-in-depth posture, revealing some of the critical vulnerabilities in the architecture, applications, and man factor. These steps including the ideas of Zero Trust and the governance models are the theoretical best practices to have cloud-hosted e-commerce security. The following chapter provides a detailed discussion of the Capital One Data Breach to demonstrate the actual impact of the lack of these basic security measures. This case is a critical demonstration of how the breach of the fundamental principles, namely, the inability to control the Shared Responsibility Model and implement the Principle of Least Privilege, directly led to a considerable loss of money and an extremely negative reputation.

6 Case Study: The Capital One Data Breach

The Capitol One data breach of 2019 is one of the biggest accidents in the financial institution cloud security aspect. Having impacted around 106 million people in the United States and Canada, the breach had revealed personal and financial details, including names, addresses, credit scores, and even Social Security numbers, that were sensitive. The reason why this case is especially relevant to the study of e-commerce and cloud security is that Capital One was generally seen as a cloud-oriented organization, as the company has already migrated to Amazon Web Services (AWS) and introduced sophisticated security solutions (encryption and tokenization). This was not a legacy system that failed but a failure in a contemporary and cloud-native environment. [1]

Technical Overview of the Breach

The attack used a set of known vulnerabilities as opposed to a zero-day exploit. The first point of entry was a misconfigured Web Application Firewall (WAF), in reverse proxy mode, that the attacker used to forward the requests to the metadata service of AWS. It was this missetting that allowed the attacker to access temporary credentials that belonged to an Identity and Access Management (IAM) role but contained too much privilege. The attacker used these credentials to access and download information on several Amazon S3 buckets. This was because the data was encrypted and the IAM role also had the ability to decrypt it which made the encryption useless in this case. Simply, the failure was not due to one source of failure but that of a series of control failures in many levels of the system. [1]

Organizational and Systemic Factors

Although the technical misconfiguration was the immediate cause, there were underlying systemic problems that led to the breach. The aggressive approach of capital one to the cloud implementation and the willingness to use open-source technologies and innovate rapidly led to the situation when security controls were not operating at the same pace as technologies. The principle of the least privilege was breached, the intrusion detection systems were unable to issue alerts and vulnerability scanning was also not sufficient. In addition, the model of shared responsibility between Capital One and AWS created ambiguity when it comes to roles and responsibilities. The belief that the inability to assure the security of the cloud is the same as the inability to assure the security in the cloud was a faulty way of thinking. The role of AWS also deserves to be mentioned. The metadata service (IMDSv1) used at AWS at the time of the breach has a vulnerability to trust API calls by EC2 instances without validating their authenticity, which was a design misuse that enabled credential harvesting. Even though AWS introduced IMDSv2 with improved protections later, this has been offered months after it.

Such a lag indicates a very serious conflict between fast innovation and hardening security in cloud service systems. [1]

Lessons Learned

Capital One case highlights the fact that cloud security is a not only a technical but also a systemic issue. The rate of technology adoption has to match the maturity of risk management practices in the organization. Trust but verify, defense-in-depth, and least privilege are security principles that should be applied stringently. Moreover, adherence to compliance as a check exercise is inadequate, security should be integrated in the organizational culture and processes. Lastly, the case brings up some critical questions regarding the regulatory control of cloud service providers, whose decision of infrastructure can have a direct effect on the security of customers.

7 Conclusion

The e-commerce platform migration to the cloud is evidently associated with some operational benefits, but the advantages are inseparably linked with significant security issues. This analysis demonstrates that data breaches, misconfigurations, and API vulnerabilities are the most detrimental security events that are most often caused by avoidable mistakes made by human error and poor governance, not necessarily problems with the technology itself. The case study about the Capital One can be seen as critical validation as the breach of the main principles, specifically, the Principle of Least Privilege, and the misunderstanding of the Shared Responsibility Model (SRM), can result in the disastrous security breaches.

A coordinated use of a layered defense approach is required to provide effective protection against such sophisticated threats. This implies that Data Protection needs to guarantee confidentiality through powerful, hardened encryption at rest and in transit, and Access Control needs to strictly impose least privilege among all user and application identities. Moreover, the Underlying Architecture should conform to high principles of isolation, segmentation, and constant verification. Lastly, the Operational Resilience and quick threat containment should be ensured with the help of centralized monitoring (SIEM systems), in-depth audit checks, and regularly tested disaster recovery plan.

Importantly, the matter of dependence on technology cannot be considered enough. There must be strict prioritization on governance and human factors. Thorough contractual limits and responsibility with providers and compulsory employee education are essential in reducing operational and human shortcomings as indicated by the case study. To sum up, companies that consider security as an essential business activity and go beyond a mere compliance attitude are the ones that will be the most successful in safeguarding sensitive data and succeed in the digital market.

References

[1] A systematic analysis of the Capital One data breach: Critical lessons learned. S. Khan, I. Kabanov, Y. Hua, and S. Madnick. *ACM Transactions on Privacy and Security*. Available at: https://dl.acm.org/doi/pdf/10.1145/3546068

[2] Cloud Computing and Data Security. *ResearchGate*, 2024. Available at: https://www.researchgate.net/publication/387786572_Cloud_Computing_and_Data_Security

[3] Systematic Literature Review on Cloud Computing Security Threats and Mitigation Strategies. *ResearchGate*, 2023. Available at: https://www.researchgate.net/publication/379332051_Systematic_Literature_Review_on_Cloud_Computing_Security_Threats_and_Mitigation_Strategies

[4] M. Chauhan and S. Shiaeles. An analysis of cloud security frameworks, problems and proposed solutions. *Network*, vol. 3, no. 3, pp. 422–450, 2023. Available at: https://www.mdpi.com/2673-8732/3/3/18

[5] Cloud Computing Security: Challenges and Solutions. *Security and Communication Networks*, Hindawi/Wiley, 2022. Available at: https://onlinelibrary.wiley.com/doi/10.1155/2022/9935244

[6] Cloud Security Challenges and Solutions: A Review of Current Best Practices. *ResearchGate*, 2024. Available at: https://www.researchgate.net/publication/387558426_Cloud_Security_Challenges_and_Solutions_A_Review_of_Current_Best_Practices

[7] A Secured Framework for E-Commerce in Cloud Computing Environment: A Literature Review. *ResearchGate*, 2021. Available at: https://www.researchgate.net/publication/356535932_A_Secured_Framework_for_E-Commerce_in_Cloud_Computing_Environment_A_Literature_Review

[8] K. Hashizume, D. G. Rosado, E. Fernández-Medina, and E. B. Fernandez. An analysis of security issues for cloud computing. *Journal of Internet Services and Applications*, vol. 4, article 5, 2013. Available at: https://jisajournal.springeropen.com/articles/10.1186/1869-0238-4-5

[9] Designing Secure and Robust E-Commerce Platform for Public Cloud. *ResearchGate*, 2023. Available at: https://www.researchgate.net/publication/379280179_Designing_Secure_and_Robust_E-Commerce_Plaform_for_Public_Cloud

[10] Design and Development of Secure Cloud Architecture for E-Commerce. *International Journal of Engineering Research & Technology (IJERT)*,

Conference Paper, 2020. Available at: https://www.ijert.org/research/design-and-development-of-secure-cloud-architecture-for-e-commerce-IJERTCONV8IS10014.pdf

[11] Privacy Issues in AI and Cloud Computing in E-commerce Setting: A Review. *International Journal of Responsible Artificial Intelligence*, NeuralSlate, 2024. Available at: https://neuralslate.com/index.php/Journal-of-Responsible-AI/article/view/44/29

[12] S. Juncai and Q. Shao. Based on Cloud Computing E-commerce Models and Its Security. *International Journal of e-Education, e-Business, e-Management and e-Learning*, vol. 1, no. 2, pp. 55–61, 2011. Available at: https://www.ijeeee.org/Papers/028-Z0016.pdf